

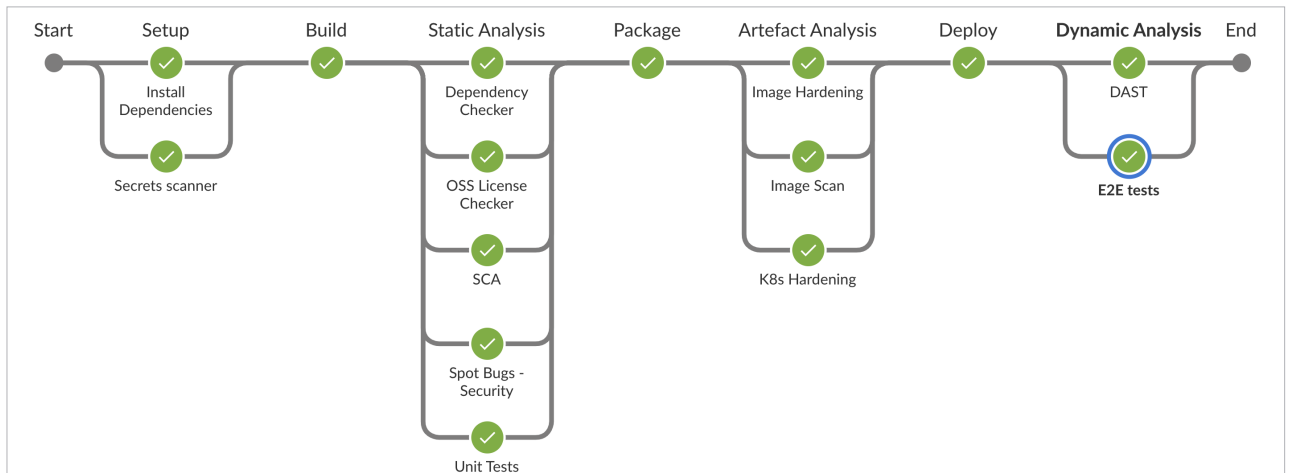


Figure 15: Sample secure pipeline (<https://github.com/rmkanda/secure-pipeline-java-demo>)

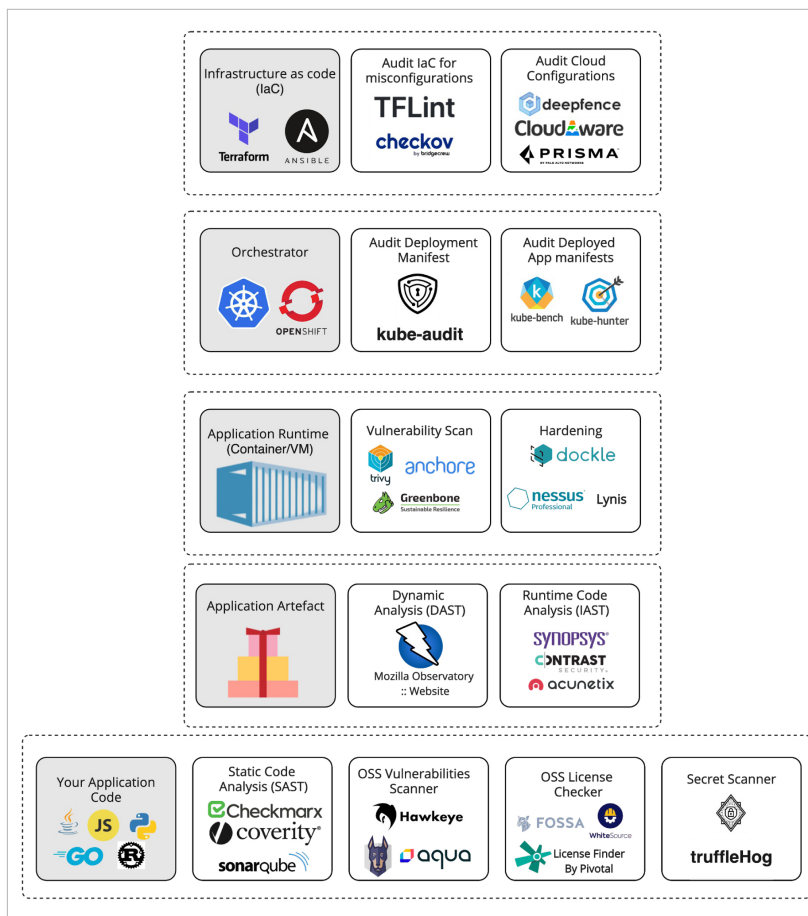


Figure 16: DevSecOps | Tools stack

By: Ramakrishnan Kandasamy

The author works at Thoughtworks Technologies, India. He is passionate about application security and has good experience in scaling security practices across enterprises, also known as DevSecOps.

Dynamic application security testing

Dynamic application security testing (DAST) performs actual attacks against the application in a sandbox environment. DAST helps us to identify common vulnerabilities in the application. For example, if an application uses cookies, these tools can check whether Secure, HttpOnly and Domain Flags are configured or not. We can use OWASP ZAP and Burp Suite to perform these kinds of checks.

OWASP ZAP API scan supports scanning of backend APIs as well. It uses the API specification JSON to test these.

Sample pipeline implementation

Considering the above practices, we have implemented a sample pipeline for a Java Tech stack. The pipeline was written to work in Jenkins. For other CI pipeline boilerplate codes, do follow me on GitHub.

Refer to my GitHub page (<https://github.com/rmkanda/tools>) for the complete set of tools available in each category. **END** 🐧

References

- [1] <https://github.com/rmkanda/secure-pipeline-java-demo>
- [2] <https://github.com/rmkanda/tools>
- [3] <https://nvd.nist.gov/general/visualizations/vulnerability-visualizations/cvss-severity-distribution-over-time>
- [4] <https://www.synopsys.com/blogs/software-security/5-open-source-trends-2020-ossra/>